Network Threats

6COSC019W- Cyber Security

Dr David Huang

February 02, 2026

Prepared by Dr Ayman El Hajjar

UNIVERSITY OF WESTMINSTER

Overview

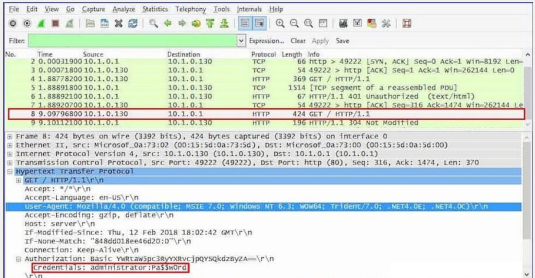
1. Network Security
2. Application layer attacks
3. Transport layer attacks
4. Network layer attacks
5. Physical layer attacks
6. Availability Threats

Malicious attacks on the rise

- Malicious cyber attacks continue to increase globally
- Ransomware and phishing remain the most common attack types
- Public, healthcare, and education sectors are frequent targets
- Major sources of cyber attacks include:
  - United States
  - China
  - Russia
  - Iran
  - North Korea
- Real-time cyber attack maps:
  - Cyberthreats real-time attacks example
  - Cyberthreats real-time attacks example

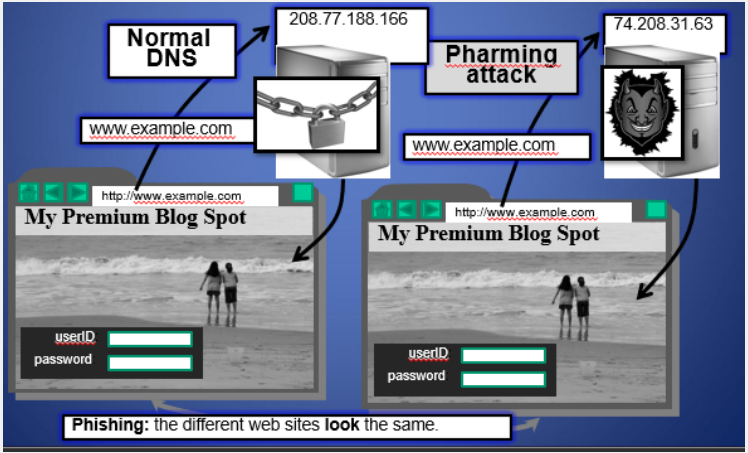
Passive Attacks- HTTP basic authentication

- Example of such attacks is the HTTP authentication:
  - HTTP basic authentication is a simple challenge and response mechanism with which a server can request authentication information (a user ID and password) from a client.
  - The client passes the authentication information to the server in an Authorization header.
  - Insecure as full credentials pass over the wire and are sent in the clear



DNS attacks- DNS Pharming

- An attacker attempt to change the IP associated with a server maliciously:

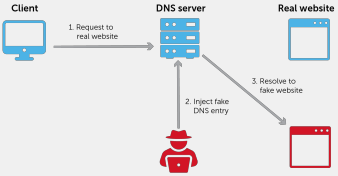


DNS ATTACKS- DNS CACHE POISONING

- **Basic idea:** Give DNS servers false records and get it cached
- There are 3 main different ways to do DNS cache poisoning.
  - The first relies on redirecting the nameserver of the attacker's domain to the nameserver of the target domain, and then assigning this target nameserver a fake IP address.
  - The second variant relies on redirecting the nameserver of another, unrelated domain to a fake nameserver.
  - The third variant just involves "racing" the real nameserver to give an answer.

- Cache may be poisoned when a name server:
  - Disregards identifiers
  - Has predictable ids
  - Accepts unsolicited DNS records

DNS poisoning



Scanning and enumeration

- Transport layer attacks starts at the early stages of the penetration testing, during the Scanning and enumeration phase.
- During the scanning and Enumeration phase, the attacker uses various tools to confirm information learned during reconnaissance and to discover new details
- Often referred to as probing: The hacker sends packets to elicit responses
- This phase aims to
  1. Probe open and closed ports of a target
  2. Identify and probe services and Operating Systems running behind those ports to obtain information them using Banner grabbing, also called fingerprinting.
  3. Discover and list potential attack targets by mapping the network.

Scanning and enumeration- Probing ports

Client | Server

SYN Request Packet
SYN/ACK Response packet
ACK Response Packet

TCP Open port- The server responds with an ACK. This determines that the port is open and a connection can be established.

```
PORT   STATE SERVICE
22/tcp open  ssh
```

SYN Request Packet
SYN/ACK Response Packet
RST Termination Packet (No ACK)

TCP half open port- The server responds with a SYN/ACK first then terminates the connection by sending a Reset message (RST). This indicates that the port is open however the request was blocked (possibly behind a firewall).

SYN Request Packet
RST Termination Packet

```
PORT   STATE  SERVICE
25/tcp closed smtp
```

TCP closed port- The server responds with a Reset message (RST) indicating that the port is closed. Closed port might indicate either that the service is not in use or blocked.

Datagram

```
137/udp open          netbios-ns
```

UDP open port- No response for a UDP request indicates that the port is open. However it can also silently mean that a firewall blocked it.

Datagram
No Response / Filtered

```
68/udp  open|filtered dhcpc
```

UDP Filtered port- The port is behind a firewall but is open.

Datagram
ICMP Type 3 Response

```
161/udp closed snmp
```

UDP closed port- ICMP type 3 response was received which indicates a closed port. Closed port might indicate either that the service is not in use or blocked.

Port Scanning types

- There are Several type of port scans (or Probes), each reveals different type of information.
- **Ping Scan**: The ping scan sends a single ICMP echo request from the source to the destination device. A response from an active device returns an ICMP echo reply, unless the IP address is not available on the network or the ICMP protocol is filtered.
- **Connect scan:** Fully connect to the target ip address and port in a complete TCP handshake. Reliable but very noisy.
- **SYN Scan:** also called half open, sends SYN requests to the target to gather information about open ports without completing the TCP handshake. When an open port is identified, the TCP handshake is reset before it can be completed.
- **FIN Scan:** FIN Scan: Sends a FIN packet to a target port. If the port is open, it silently drops the packet and does not respond. If the port is closed, it sends back a RST error response.

Scanning and enumeration

Map Network

```
└─$ sudo nmap -sn -system-dns -sn 192.168.56.*
Starting Nmap 7.93 ( https://nmap.org ) at 2024-12-24 04:46 GMT
Nmap scan report for 192.168.56.1
Host is up (0.00085s latency).
MAC Address: 0A:00:27:00:00:14 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.000040s latency).
MAC Address: 08:00:27:FB:26:38 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up (0.0019s latency).
MAC Address: 08:00:27:FE:6E:FA (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.103
Host is up (0.0011s latency).
MAC Address: 08:00:27:5F:19:98 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.102
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 1.96 seconds
```

Identify the target IP range.
Discover live hosts.
Visualise vulnerable devices.

Services Fingerprinting

```
PORT     STATE  SERVICE     VERSION
21/tcp   open   ftp         ProFTPD 1.3.5
22/tcp   open   ssh         OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.1
80/tcp   open   http        Apache httpd 2.4.7 ((Ubuntu))
445/tcp  open   netbios-ssn Samba smbd 3.X - 4.X (workgroup:
631/tcp  open   ipp         CUPS 1.7
3000/tcp closed ppp
3306/tcp open   mysql       MySQL (unauthorized)
8080/tcp open   http        Jetty 8.1.7.v20120910
8081/tcp closed intermapper
```

Open ports reveal running services.
Identify vulnerable services.
Research possible exploits.

Operating System Fingerprinting

```
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.9
```

Different OSs respond differently.
Responses reveal the OS.

Banner grabbing

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV --script banner cwscenario.site
Starting Nmap 7.93 ( https://nmap.org ) at 2024-12-24 04:48 GMT
Nmap scan report for cwscenario.site (217.160.0.219)
Host is up (0.024s latency).
Other addresses for cwscenario.site (not scanned): 2001:8d8:100f:f000::2b6
rDNS record for 217.160.0.219: 217-160-0-219.elastic-ssl.ui-r.com
Not shown: 998 filtered tcp ports (no-response)
PORT    STATE SERVICE  VERSION
80/tcp  open  http     nginx
|_http-server-header: Apache
443/tcp open  ssl/http nginx
|_http-server-header: Apache
|_http-trane-info: Problem with XML parsing of /evox/about
```

Collect service details from banners.

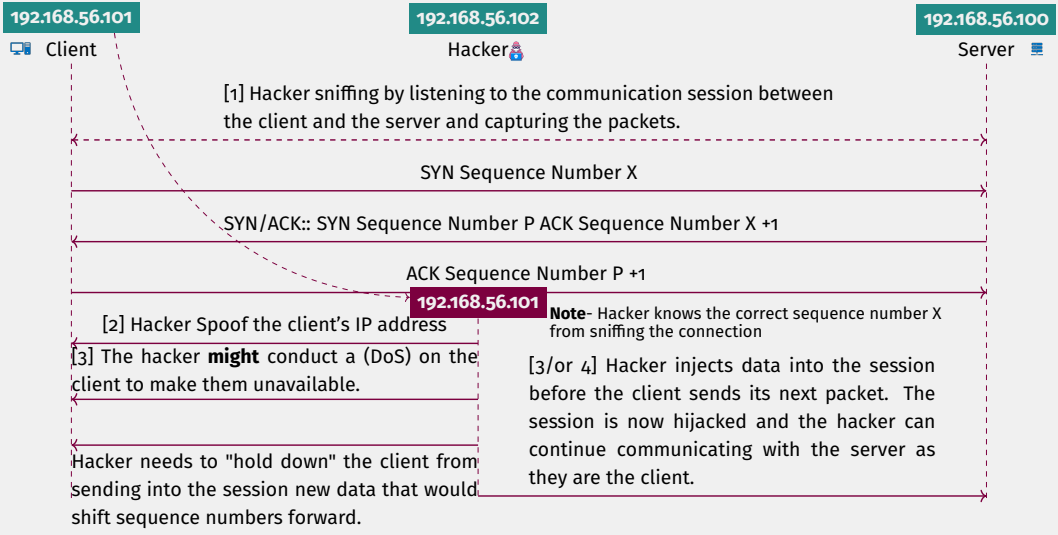
Session Hijacking

- Session hijacking builds on sniffing the network.
- The goal is not only to observe traffic and sessions currently active on the network but also to take over a session that has authenticated access to the resource
- Occurs when attackers use a valid session to gain unauthorised access to a system, information, or service
- Target authentication, which typically takes place at the beginning of a session, making session hijacking possible after that point
- Relies on a basic understanding of how messages and their packets flow over the Internet
- Session hijacking takes advantage of the fact that most communications are protected from the beginning at session setup, such as by providing credentials, but not during the session.

Session Hijacking (Cont.)

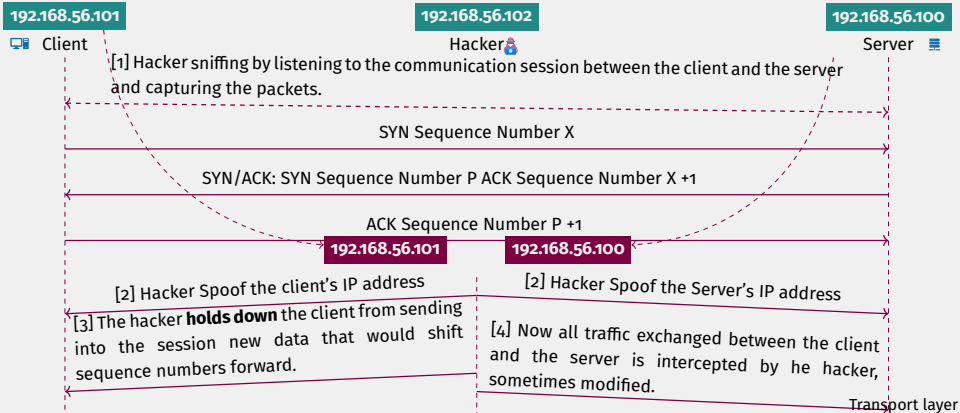
- In a session hijacking attack, an attacker takes control of or modifies any communications between two hosts by:
  - Positioning themselves between communicating parties and Party B (meaning being able to sniff the communication).
  - Monitor the flow of packets using sniffing techniques.
  - Analyse and predict the sequence number of the packets.
  - Sever the connection between the two parties.
  - Seize control of the session.
  - Perform packet injection into the network.
- Session hijacking attacks generally fall into the following three categories:
  - Session hijack attacks
  - Man in the middle attack
  - Blind hijack attacks
  - Session replay attacks

Session hijack attack



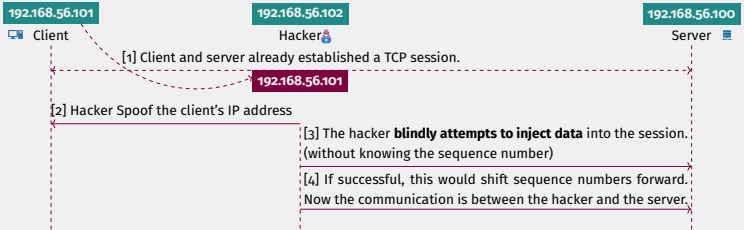
Man in the middle attack (MiTM)

- An attacker intercepts all communications between two hosts.
- The attacker positions themselves so that communications between a client and server must flow through them, which allows them to modify the communications.



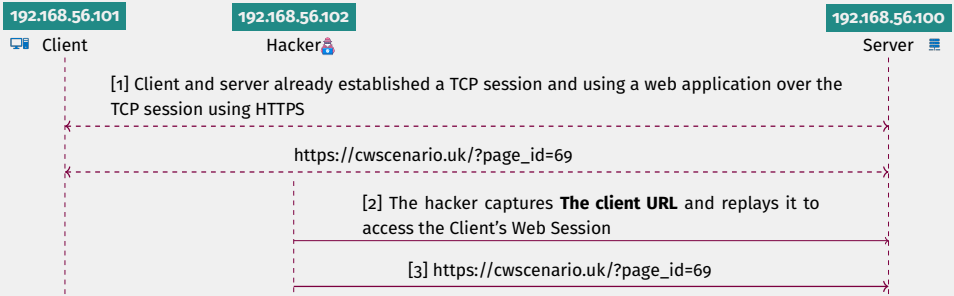
Blind hijack attack

- An attacker can inject data such as malicious commands into those communications
- This type of attack is called blind hijacking because the attacker can only inject data into the communications stream;
- The attacker cannot see the response to that data, such as "The command completed successfully.
- For a session hijack to be successful, attacker must successfully determine or guess the sequence numbers to hijack a session.



Session replay attack

- In a session replay attack also called session theft attack, the attacker is neither intercepting nor injecting data into existing communications between two hosts.
- Instead, the attacker utilises old sessions (Repeat them).
- This type of session hijacking attack is most common at the application level, such as a Web application.



IP Vulnerabilities

- Unencrypted transmission
  - **Eavesdropping** possible at any intermediate host during routing
- No source authentication
  - Sender can **spoof source address**, making it difficult to trace packet back to attacker
- No integrity checking
  - Entire packet, header and payload, can be modified en route to destination, enabling **content forgeries**, **redirections**, and **man-in-the-middle** attacks
- No bandwidth constraints
  - Large number of packets can be injected into network to launch a **denial-of-service** attack

IP SPOOFING ATTACKS

- IP Spoofing is an attempt by an intruder to send packets from one IP address that appear to originate at another
- If the server thinks it is receiving messages from the real source after authenticating a session, it could inadvertently behave maliciously
- There are two basic forms of IP Spoofing
  - Blind Spoofing
    - Spoof IP address without inherently knowing the ACK sequence pattern.
  - Non-Blind Spoofing
    - Spoof IP address after identifying correct ACK sequence.

IP SPOOFING ATTACKS

- For both to succeed, the spoofed IP cannot exist with another user on the network.
- ✦ **Remember**: Two devices with the same IP connect exist on a network. For this attack to be successful, the spoofed IP cannot exist on the network. For Non blind IP spoofing, the attacker usually conduct a Denial of Service attack on the genuine client rendering them unavailable.
- For Non Blind spoofing, the attacker would:
  - Analyse the network packets using a packet sniffer,
  - Determine the ACK sequence pattern
  - Spoof the IP of an actual client and send packets with the correct sequenced acknowledgment number

Sniffers

- An application or device designed to capture, or “sniff,” network traffic as it moves across the network
- A technology used to steal or observe information
- Allows viewing of email passwords, web passwords, File Transfer Protocol (FTP) credentials, email contents, and transferred files
- When a network adapter is put in promiscuous mode **(also called monitor mode)**, a sniffer then realise its full potential, including sniffing all traffic regardless of the destination address.
  - In normal mode the network adaptor drops or ignores any packet not intended for it
  - In promiscuous mode the network adaptor captures all traffic it can hear.

Sniffers Threats to protocols

- Telnet — Keystrokes can be easily sniffed if transmitted over Telnet
- Hypertext Transfer Protocol (HTTP) — Designed to send information in the clear without any protection and is a good target for sniffing
- Simple Mail Transfer Protocol (SMTP) — Commonly used in the transfer of email; is simple and efficient but does not include protection against sniffing
- Post Office Protocol (POP) — Is designed to retrieve email from servers but does not include protection against sniffing because passwords and usernames can be intercepted
- File Transfer Protocol (FTP) — A protocol designed to send and receive files; all transmissions are sent in the cleare

Sniffers methods

Passive Sniffing

- Difficult to detect
- Takes place and is effective when a hub is present
- Can be done very simply

Active Sniffing

- Easier to detect
- Intercepts and forces traffic through the attacker's device
- Requires more technical effort

MAC Flooding

- The goal of MAC flooding is to flood the switch with fake MAC addresses to all ports.
- This will cause the switch Content Addressable memory (CAM) to be filled and the switch overwhelmed resulting the switch failing.
  - Content Addressable memory (CAM) is used to build a lookup table
  - Lookup table tracks which MAC addresses are present on which ports on the switch
  - CAM allows a lookup to be performed to let the switch get traffic to the correct port and host
- MAC flooding is considered an active sniffing attack.
- MAC flooding tools includes; EtherFlood, SMAC, and macof MAC Address Changer

MAC Filtering and MAC Spoofing

MAC Filtering

- The administrator creates an **allow** or **block** list of MAC addresses.
- Wireless networks often use MAC filtering to restrict device access.

- A MAC spoofing attack impersonates another device.
- The attacker finds the target MAC address using a packet sniffer.
- The rogue device changes its MAC address.
- The target device is disconnected.
  - MAC filtering is easy to bypass by spoofing the MAC address.

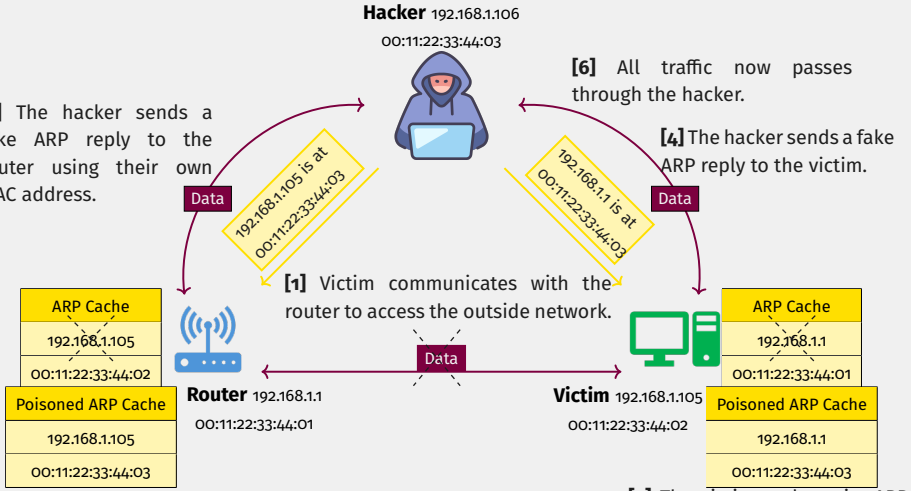
ARP Spoofing

- ARP spoofing manipulates the ARP cache by sending forged (spoofed) ARP packets, tricking devices on the network into associating the attacker's MAC address with a legitimate IP address.
- This is possible for several reasons:
  - The ARP table is updated whenever an ARP response is received
  - ARP Requests are not tracked
  - ARP Requests are not authenticated
  - Machines inherently trust other devices on the same network.
- Allowing a rogue machine to impersonate (spoof) another machine on the network.

ARP Poisoning : How does it work!

- Once a MAC address is spoofed, an attacker can conduct ARP poisoning attack.
- The basic idea of ARP poisoning is for the attacker to attach itself to a network with a valid IP address and a spoofed MAC address from the switch ARP table stored in the CAM.
- ARP poisoning is an active sniffing attack on IPv4 networks.
- The attacked sends **unnecessary arp replies** to “poison” an arp cache.
- The arp cache updates every time that it receives an arp reply! Even if it did not send any arp request!
  - The attacker first need to stop the client from sending into the session new data
  - To do this, the attacker sends injected data before the real client or disrupts the client with a DoS attack.

ARP Poisoning : How does it work!



Denial-of-Service Attacks

Denial-of-Service Attack

- One of the most common attacks. It prevents users from accessing system services.
- Availability attacks are used when no vulnerability can be exploited.

- Aimed at consuming resources or disrupting a service, exploiting system limitations:
  - Number of users
  - File size
  - Transmission speed
  - Stored data
- Some DoS attacks exploit software defects to cause crashes.

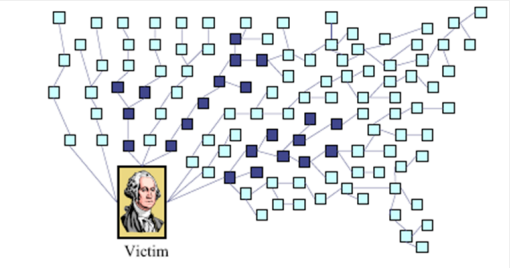
Distributed Denial of service attack

- A DoS attack attempts to prevent valid users from accessing network resources.
- A distributed denial of service (DDoS) attack has the same goal but amplifies the DoS attack by using multiple hosts.
- Whereas a DoS attack would overwhelm the network connection for a targeted host through a more powerful host, a DDoS attack would use multiple intermediary hosts to generate enough traffic to disrupt server farms or a whole network segment, and possibly beyond.
- A challenge to detect a DDos is that traffic is coming from several ip addresses. That makes it more difficult to detect until it is too late
- Foundations are agents, bots, or zombies, which are malicious code implanted on victim systems across the Internet

Distributed Denial of Service Attack

- Uses hundreds or thousands of systems to conduct attack
- Has primary and secondary victims
- Attack can be difficult or impossible to track back to source
- Defence is difficult, and impact is higher than DoS attack, due to number of attackers

DDoS



DoS/DDoS Attacks at the network level

- ICMP flood
  - Ping flood: Carried out by sending a large number of ping packets to the victim with the intent of overwhelming the victim; very simple attack

```
┌──(kali㉿kali)-[~]
└─$ sudo hping3 -S --flood --rand-source 192.168.56.103
HPING 192.168.56.103 (eth0 192.168.56.103): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
```

Figure 1: A simple ICMP flood on the OWASP VM

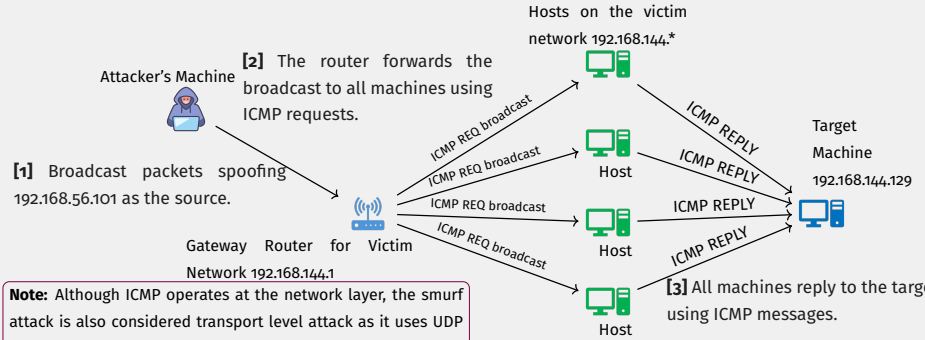
  - Smurf attack: Hacker sends ICMP broadcast with a spoofed IP of the victim. All network devices responds to the victim with an ICMP echo, overwhelming the victim and the network.

Network level DoS/ DDoS

- Reflected attack
  - Is carried out by spoofing or forging the source address of packets or requests and sending them to numerous systems, which in turn respond to the request; a scaled-up version of what happens in the ping flood attack
- DHCP starvation
  - If enough requests flooded onto the network, the attacker can completely exhaust the address space allocated by the DHCP servers for an indefinite period of time. This is a DoS attack is called DHCP starvation. There are An attacker can use a tools such as The Gobbler that will do this for the attacker to easily commit this type of attack.

Network level DoS/ DDoS- Smurf attack

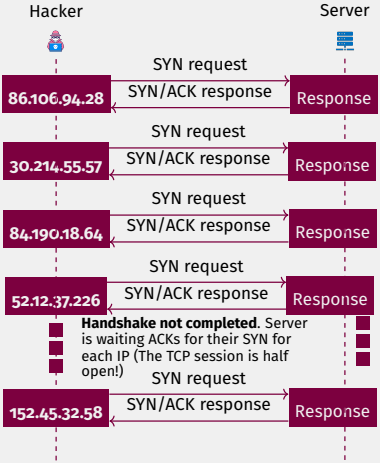
- Hacker sends ICMP broadcast with spoofed IP
- Intermediaries respond with replies
- ICMP echo replies will flood victim
- The network performs a DDoS on itself



Note: Although ICMP operates at the network layer, the smurf attack is also considered transport level attack as it uses UDP to send the ICMP messages

Transport level DoS/ DDoS- SYN flood

- Uses forged packets with the SYN flag set;
- when the victim receives enough of the packets, the result is an overwhelmed system as the SYN flood consumes connection resources to the point where no resources are available for legitimate connections
  - Hacker sends out a SYN packet
  - Receiver must allocate space in buffer
  - Client responds with the ACK flag set



Transport level DoS/ DDoS- UDP flood

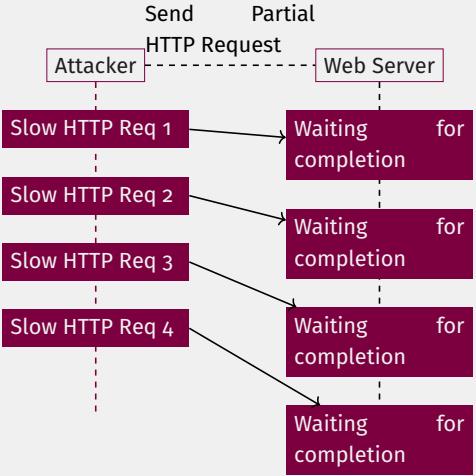
- Hacker sends UDP packets to a random port
- Generates illegitimate UDP packets
- Causes system to tie up resources sending back packets

```
┌──(kali㉿kali)-[~]
└─$ sudo hping3 -2 --flood --rand-source -p 80 192.168.56.103
^C
HPING 192.168.56.103 (eth0 192.168.56.103): udp mode set, 28 headers + 0 data bytes
hping in flood mode, no replies will be shown
```

Figure 2: Flooding the OWASP VM with UDP packets

Application level DoS/ DDoS

- HTTP flood
  - Attack that bombards Web servers with HTTP requests
  - Consumes considerable resources
- Slowloris - A more potent variant
  - Attempts to monopolise by sending HTTP requests that never complete
  - Eventually consumes Web server's connection capacity
  - Utilises legitimate HTTP traffic



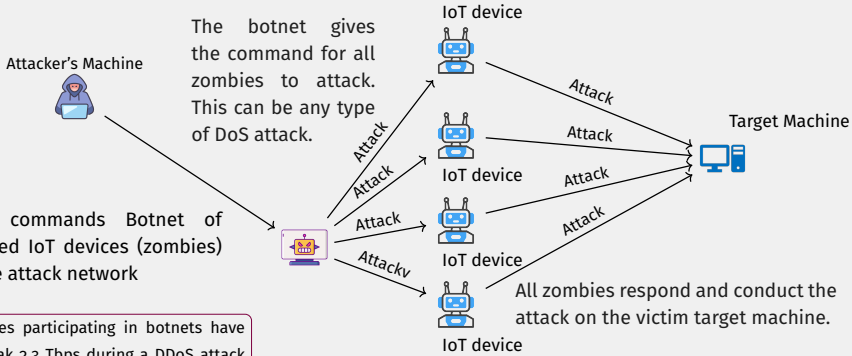
DoS/DDoS Attacks: Exploitation of Programming Defects

- The Ping of Death (PoD)
  - Some systems cannot handle oversized packets; .
  - An attacker sends them out in fragments, when fragments reach the system, they are reassembled by the victim;
  - When the maximum size (65,536 bytes) allowed by the IP protocol is reached, some systems will crash
- Teardrop Attack
  - Packets are sent in a malformed state with their offset values adjusted so they overlap, which is illegal;
  - Victim system attempts to reconstruct message. when a system that does not know how to deal with this issue is targeted, a crash or lock may result
- Land Dos
  - A packet is sent to a victim's system with the same source and destination address and port; systems that do not know how to process this will crash

Botnets and the Internet of Things (IoT)

- The Internet of Things made is possible to conduct a very large scale DDoS by weaponising IoT devices such as low power devices and smart devices to participate in the attack.
- It is very challenging to respond to such attacks as the traffic is coming from a large number of devices in different networks.
- Devices participating in the attack are called Zombies devices. The Network of zombies devices is called a Botnet.
- Botnets attacks include:
  - DDoS attacks — This attack method based is on the way a DDoS works and the number of systems that are infected.
  - Click fraud — Attacks to generate revenue for themselves via Ads by using large number of infected devices.
  - Stealing information — Attacks have also been carried out with botnets to steal information from unsuspecting users' systems.

DDoS using an IoT botnet



Note: IoT devices participating in botnets have generated at peak 2.3 Tbps during a DDoS attack on Amazon Web Services in 2020.

Mapping the OSI Model to Cyber Threats

Layer 7	Application	Application attacks, DNS attacks, buffer overflow, HTTP Flood, exploit code, malicious software(Viruses, trojans, worms)
Layer 6	Presentation	NetBIOS enumeration, clear text extraction and protocol attacks
Layer 5	Session	Session Hijacking, SYN attacks, and password attacks
Layer 4	Transport	Port Scanning, port knocking, MiTM, Blind hijack, DOS attacks, SYN Flood, Service enumeration and flag manipulation
Layer 3	Network	IP attacks, routing attacks, Ip spoofing, Ping of Death (PoD) attack, DHCP Starvation, and ICMP assaults such as ICMP flood and Smurf attack
Layer 2	Data Link	Passive and active sniffing, MAC spoofing and poisoning, MAC flooding, and WEP cracking
Layer 1	Physical	Hardware hacking, physical access, wiretapping and interception

References

- The lecture notes and contents were compiled from my own notes and from various sources.
- Figures and tables are from the recommended books
- **The lecture notes are very detailed. If you attend the lecture, you should be able to understand the topics.**
- **You can use any of the recommended readings! You do not need to read all the chapters!**
- **Recommended Readings note:** Focus on what was covered in the class.
  - Chapter 11- Sniffers, Session Hijacking, and Denial of Service Attacks, Hacker Techniques, Tools, and Incident Handling
  - Chapter 4- Denial of Service Attacks, Computer Security Fundamentals